CYBERSECURITY ASSESSMENT REPORT

Controlled Virtual Lab • Network Reconnaissance • SSH Security
Authentication • Firewall Validation

Project	Cybersecurity-Assessment-Lab
Environment	Two Kali Linux virtual machines hosted in Oracle VirtualBox
Assessment VM	192.168.56.101
Target VM	192.168.56.103
Primary service	OpenSSH over TCP/22
Assessment scope	Controlled educational lab environment

Reporting note: This report documents observed activities and results available in the project record. It does not claim a production-grade audit, a comprehensive vulnerability assessment, or evidence that was not collected.

Prepared for educational portfolio documentation.

1. Executive Summary

This report summarizes a hands-on cybersecurity assessment performed in a controlled VirtualBox environment using two Kali Linux virtual machines. The work examined network reachability and service exposure, SSH traffic behavior, remote-session visibility, Linux account and permission controls, password-hash testing, and defensive hardening through SSH configuration and UFW firewall rules.

Final validation confirmed that the target SSH service remained reachable on TCP/22. Password authentication was disabled in the tested SSH configuration, public-key authentication remained available, and a password-only SSH attempt was rejected. After UFW was enabled, the public-key connectivity test continued to succeed. The final Nmap scan reported TCP/22 as open and the other 999 scanned TCP ports as filtered or not responding.

Password-hash testing was limited. A synthetic MD5 test hash was recovered in a John the Ripper demonstration. The target account's yescrypt hash was not successfully cracked; the attempted load returned `No password hashes loaded`. These are separate outcomes and are not conflated.

Overall conclusion: The lab demonstrated practical techniques for observing network and SSH behavior and validating selected defensive controls. Findings apply only to the tested virtual environment.

2. Scope and Lab Architecture

Testing was restricted to two virtual machines controlled by the project owner. The described work did not target external systems or third-party infrastructure.

Component	Observed / configured detail
Virtualization platform	Oracle VirtualBox
Operating systems	Kali Linux on both virtual machines
Assessment VM	192.168.56.101
Target VM	192.168.56.103
Service examined	OpenSSH, TCP port 22
Network discovery	ICMP checks and Nmap TCP scans
Traffic inspection	Wireshark capture of SSH setup and protocol metadata

In-scope activities included reconnaissance, protocol observation, session inspection, review of account information and permissions, a controlled password-hash demonstration, SSH hardening, firewall activation, and post-change validation.

3. Methodology

Chapter 1 — Network reconnaissance. Checked ICMP reachability and used Nmap to observe target availability and TCP service state.

Chapter 2 — SSH traffic analysis. Captured SSH setup traffic in Wireshark and reviewed the TCP three-way handshake, protocol banners, key-exchange metadata, and transition to encrypted traffic.

Chapter 3 — SSH sessions and system inspection. Established an SSH session and inspected user/session information, service status, active connections, and available system logs.

Chapter 4 — Linux authentication and permissions. Reviewed `/etc/passwd` and `/etc/shadow`, file access boundaries, user identity, group membership, and the target account hash format.

Chapter 5 — Password-hash testing. Checked John the Ripper compatibility and tested a synthetic MD5 hash separately from the target account's yescrypt hash.

Chapter 6 — Hardening and validation. Configured SSH to disable password authentication, validated configuration, tested public-key and password-only access, enabled UFW, and ran a final Nmap scan.

4. Technical Findings

4.1 Network reachability and service discovery

When the target VM was powered off, the assessment VM received `Destination Host Unreachable` and the ping test showed 100% packet loss. After the target was started, ICMP connectivity succeeded. An initial Nmap scan found the host up while the default 1,000 scanned TCP ports were reported closed/reset. After SSH was started on the target, TCP/22 appeared open.

Interpretation: The observations show that target availability and service state changed with the VM and SSH service state. Closed and filtered port states are distinct and are reported separately.

4.2 SSH protocol and encrypted traffic

Wireshark showed TCP connection setup from client source port 59968 to destination TCP/22, followed by the TCP three-way handshake. SSH banners identified `OpenSSH_10.2p1 Debian-2`. Captured negotiation metadata included the key-exchange method `mlkem768x25519-sha256` and cipher `chacha20-poly1305@openssh.com`. After key exchange and key activation, packet contents were observed as encrypted SSH traffic.

Interpretation: The capture exposed connection setup and negotiation metadata, but did not expose the protected contents of the established SSH session.

4.3 SSH session and system inspection

An SSH session was established from the assessment VM to the target. Commands including `whoami`, `who`, `who am i`, `ss`, `systemctl`, and `last` were used to inspect identity, logged-in sessions, active connections, service state, and available login history. The SSH service was observed active. The expected `/var/log/auth.log` file was not present in this environment, so available system journal logs were considered instead.

A separate “timeout before authentication” message was observed. The available observations did not establish that it was caused by an attack, so no such attribution is made.

4.4 Linux authentication and permissions

The lab reviewed account-entry structure in `/etc/passwd` and the role of `/etc/shadow` in storing password-hash information. Access to `/etc/shadow` was denied in a non-privileged context. The current user identity and group memberships, including `sudo`, were reviewed. The target account hash was identified as using yescrypt, indicated by the `$y$` prefix.

Interpretation: The observed file permissions illustrate separation between general account metadata and sensitive password-hash data. Membership in the sudo group indicates potential administrative privilege through sudo policy; it does not mean every command automatically runs as root.

4.5 Password-hash testing with John the Ripper

The installed John the Ripper build was recorded as `1.9.0-jumbo-1+bleeding-aec1328d6c`. An attempt to load the target account's yescrypt hash returned `No password hashes loaded`. This indicates that the attempted input was not loaded for cracking in that run; it does not prove that the password is strong or weak.

A separate synthetic MD5 hash was tested with a small wordlist, and the demonstration reported one recovered hash. An incremental attempt ran for approximately 11 minutes and 45 seconds, was manually interrupted, and did not recover a password during that attempt.

Important distinction: The recovered value belonged to the synthetic MD5 demonstration only. No successful recovery of the target account's yescrypt password was demonstrated.

4.6 SSH hardening and firewall validation

A dedicated SSH configuration drop-in was created at `/etc/ssh/sshd_config.d/00-lab-hardening.conf` with `PasswordAuthentication no`. The syntax check using `sudo sshd -t` completed without error output. Effective configuration from `sudo sshd -T` included `passwordauthentication no`, `pubkeyauthentication yes`, and `permitrootlogin prohibit-password`. The SSH service was reloaded.

Post-change testing confirmed that public-key SSH access succeeded and returned the target address 192.168.56.103. A password-only SSH test was rejected with `Permission denied (publickey)`.

UFW was initially inactive. An allow rule for OpenSSH was applied and the firewall was enabled. Reviewed rules included an OpenSSH allow rule and inbound deny rules for ports 1234 and 2222 in IPv4 and IPv6. The available record does not establish whether those two deny rules were created during this chapter or already existed.

After UFW activation, the public-key SSH connectivity test continued to succeed. The final Nmap scan reported 22/tcp open (OpenSSH 10.2p1 Debian 2) and 999 other scanned TCP ports as filtered or receiving no response.

Interpretation: The tested configuration blocked password-only SSH authentication while preserving public-key access. The final scan supports the observation that TCP/22 remained reachable and the other scanned ports did not respond as open; it does not establish that those ports were closed.

5. Findings and Validation Summary

Area	Observed result	Assessment statement
Network discovery	Target reachable when VM was on; TCP/22 became open after SSH started.	Service state was observable and dependent on target/service availability.
SSH traffic	TCP handshake, SSH banners, key-exchange metadata, encrypted traffic after key setup.	Connection setup and negotiation metadata were visible in capture.
Account permissions	Non-privileged access to /etc/shadow denied; target hash used yescrypt.	Sensitive hash data was protected by the observed access boundary.
Password testing	Synthetic MD5 recovered; target yescrypt hash not loaded successfully.	Only the synthetic demonstration produced a recovered hash.
SSH authentication	Public-key test succeeded; password-only test rejected.	Observed behavior matched intended password-authentication hardening.
Firewall / final scan	UFW enabled; TCP/22 open; 999 other ports filtered/no response.	SSH remained reachable; other ports are not confirmed closed.

6. Recommendations

- Preserve configuration evidence: Include sanitized copies of the final SSH drop-in and UFW status/rule output in the repository when available. Do not publish secrets.
- Maintain key-based SSH access: Keep password authentication disabled where appropriate, protect private keys, and review authorized-key management.
- Review SSH exposure: Restrict SSH reachability to trusted source networks where feasible, and document any lab-specific broad access.
- Validate firewall rules: Record complete UFW status and rule ordering, and document the purpose of each explicit allow or deny rule.
- Apply least privilege: Review sudo group membership and use administrative privileges only when required.
- Use compatible hash-audit tooling: Confirm that the selected tool supports the hash format and input structure. Treat loading errors as compatibility/input issues until investigated.
- Capture reproducible evidence: Maintain organized screenshots and command output for important validation steps. Evidence files are maintained separately in the project repository.
- Re-test after changes: Consider further documented checks of SSH cryptographic policy, operating-system updates, account exposure, and logging.

7. Limitations

- The assessment used a small controlled virtual lab and was not a comprehensive audit of a production system.
- Evidence screenshots are maintained in chapter-specific repository folders; the report references the evidence index rather than embedding every screenshot.
- The absence of /var/log/auth.log was observed in this environment; available system journal logs were considered instead.
- The target's yescrypt hash was not successfully cracked. The successful John the Ripper result was limited to a synthetic MD5 hash.
- The final Nmap result for 999 ports was filtered/no-response, not confirmed closed.
- The origin and timing of the UFW deny rules for ports 1234 and 2222 could not be confirmed from the available notes.
- The SSH pre-authentication timeout message was not attributed to malicious activity.
- Results reflect the recorded configuration and validation steps; no claim is made that every possible attack path or vulnerability was tested.

8. Conclusion

The Cybersecurity-Assessment-Lab project demonstrates an introductory end-to-end workflow for examining network visibility, observing SSH connection setup, reviewing Linux authentication boundaries, carrying out a limited password-hash demonstration, and validating defensive changes. The strongest directly validated hardening result was the rejection of password-only SSH authentication while public-key access continued to work after the SSH configuration change and UFW activation.

The report preserves important limitations: the target's yescrypt password was not recovered, filtered ports were not treated as closed, and evidence is described only at the level supported by the project record. These distinctions keep the report aligned with the observed lab results and provide a sound basis for further documented practice.

Appendix A. Selected Configuration and Validation Details

SSH configuration drop-in path

`/etc/ssh/sshd_config.d/00-lab-hardening.conf`

Setting	Observed effective value
PasswordAuthentication	no
PubkeyAuthentication	yes
PermitRootLogin	prohibit-password

The SSH syntax validation command completed without error output. The post-change public-key connection succeeded, while the password-only connection was rejected. The final scan reported TCP/22 open and 999 other scanned TCP ports filtered or not responding.

Appendix B. Evidence Index

Screenshots are stored separately in the repository under the following chapter-specific folders. Filenames and contents should be checked during final repository organization.

Folder	Evidence focus
evidence/chapter-01-network-recon/	ICMP reachability and Nmap service discovery.
evidence/chapter-02-wireshark/	SSH TCP setup, protocol banners, key exchange, encrypted traffic.
evidence/chapter-03-ssh-sessions/	SSH session identity, active connections, SSH service status.
evidence/chapter-04-linux-auth/	Account structure, shadow permissions, identity and privileges.
evidence/chapter-05-john-the-ripper/	Synthetic MD5 demonstration and target yescrypt loading result.
evidence/chapter-06-hardening-firewall/	SSH hardening, public-key/password-only tests, firewall and final scan.

Evidence note: The index describes the intended repository organization. Confirm that each listed folder contains the corresponding files before publishing the repository.